

Security incident report

Section 1: Identify the network protocol involved in the incident

After analyzing the traffic log captured with tcpdump, two main protocols of the TCP/IP model's application layer were identified as facilitating the connection and the attack:

DNS (Domain Name System): It was used to translate the URLs yummyrecipesforme.com and the malicious URL greatrecipesforme.com into their respective IP addresses. The log shows requests to the DNS server (dns.google.domain) and the corresponding responses with the destination IPs.

HTTP (Hypertext Transfer Protocol): It was used for the request of the main web page, the download of the malicious executable file, and the subsequent communication with the fake website. The control flags in the log (such as Flags [P.] and the GET methods) confirm the transfer of data and requests for web resources.

Section 2: Document the incident

Event description: An external attacker (identified as a former employee) gained unauthorized access to the administrative panel of yummyrecipesforme.com via a brute-force attack.

Method of entry: Access was possible due to the use of default credentials on the administrator account, which were guessed by the attacker after multiple attempts.

Technical impact: Once inside, the attacker injected malicious JavaScript code into the site's source code. This script prompted visitors to download a

supposed browser update that contained redirection malware.

Discovery: The incident was reported by customers who noticed slowness on their computers and were involuntarily redirected to the domain greatrecipesforme.com, where protected company content was exposed.

Evidence: The compromise was confirmed by analyzing the source code and using a sandbox environment, where tcpdump logs showed the flow of traffic to the unauthorized redirection domain.

Section 3: Recommend one remediation for brute force attacks

To prevent future compromises of this nature, the immediate implementation of the following measures is recommended:

Two-Factor Authentication (2FA): This is the most effective measure against credential theft. By requiring a second factor (such as a code sent to a mobile phone or biometrics), it ensures that even if the attacker guesses the password through brute force, they cannot access the administrative panel without the second security component.

Login Attempt Limitation: Configure the server to temporarily block any IP address that fails a certain number of attempts (e.g., 5 attempts). This stops automated scripts that try thousands of password combinations per second, making a brute-force attack unfeasible in terms of time.